

Network Architecture Assessment Report

Prepared by: Omkar Sawant

Client: GlobalTech Corp (Sample Network)

Date: 22 May 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

1. Executive Summary

- This report presents the findings of a current-state security assessment conducted on the sample network of GlobalTech Corp, a multinational corporation with a headquarters in Mumbai, two remote offices, and approximately 300 remote employees.
 - The assessment identified 15 security findings across five domains:
 - perimeter security
 - network segmentation
 - remote access
 - endpoint and identity management
 - and data protection and visibility.
- Of the 15 findings, 7 are rated High or Critical severity.
 - The most significant risks include the absence of network segmentation, missing multi-factor authentication,
 - a legacy VPN implementation,
 - and no deployed intrusion detection or prevention system.
- These gaps collectively expose the organisation to lateral movement attacks, credential compromise, and undetected intrusion.
- Immediate remediation is recommended for all High-severity findings before proceeding with the proposed secure architecture implementation.

2. Methodology

The assessment was conducted using the following approach:

- **Network topology review:** examination of existing network diagrams, device inventory, and traffic flows
- **Configuration analysis:** review of firewall rules, VLAN configurations, VPN settings, and access control policies
- **Identity and access review:** audit of user accounts, privilege levels, and authentication mechanisms
- **Endpoint inventory:** assessment of endpoint protection tools and device compliance posture
- **Data flow analysis:** identification of sensitive data paths and encryption coverage

Findings are rated by severity as follows:

- **High:** exploitable vulnerability with direct risk of data breach or system compromise
- **Medium:** weakness that increases risk but requires additional conditions to exploit
- **Low:** best-practice gap with limited immediate impact

3. Findings and Recommendations

3.1 Perimeter Security

Finding 1: Legacy stateful firewall — no application-layer inspection [HIGH]

- The organisation's perimeter is protected by a legacy stateful firewall that performs port and protocol filtering only.
- It has no capability to inspect application-layer traffic, identify threats embedded in permitted protocols, or enforce application-specific policies.
- **Recommendation:**
 - **Replace the legacy firewall with a next-generation firewall (NGFW) such as Palo Alto Networks PA-Series or Fortinet FortiGate.**
 - **Configure application identification, SSL/TLS inspection, and threat intelligence feed integration.**

Finding 2: Overly permissive outbound firewall rules [HIGH]

- Outbound firewall rules permit any internal host to connect to any external destination on ports 80 and 443.
- This configuration allows malware, data exfiltration tools, and command-and-control traffic to operate freely over standard web protocols.
- **Recommendation:**
 - **Implement allowlist-based egress filtering.**
 - **Restrict outbound connections to known-good destinations.**
 - **Route all web traffic through a web proxy for inspection and logging.**

Finding 3: No intrusion detection or prevention system deployed [MEDIUM]

- There is no IPS/IDS in place. Intrusion attempts, port scans, exploit payloads, and anomalous traffic patterns pass through the network without detection or alerting.
- **Recommendation:**
 - **Deploy an inline IDPS such as Snort, Suricata, or a commercial solution.**
 - **Maintain up-to-date signature feeds and configure alerts for high-confidence detections.**

3.2 Network Segmentation

Finding 4: Flat network — no VLAN segmentation [HIGH]

- All departments including HR, Finance, IT operations, and general users; share a single broadcast domain.
- A compromised endpoint in any department can communicate directly with all servers and devices on the network without restriction.
- **Recommendation:**
 - **Design and implement a VLAN architecture segmenting traffic by function:**
 - User VLAN
 - Server VLAN
 - Finance VLAN
 - HR VLAN
 - DMZ
 - IoT
 - and Guest.
 - Use inter-VLAN routing with strict access controls.

Finding 5: No ACLs between network segments [HIGH]

- Even where logical separation exists, no access control lists are in place to restrict traffic between the user network and the server network.
- This allows lateral movement from a compromised endpoint to critical servers.
- **Recommendation:**
 - **Implement ACLs on all inter-VLAN routing interfaces.**
 - **Apply the principle of least privilege:**
 - **Permit only the specific ports and protocols required for each segment's business function.**

Finding 6: Guest Wi-Fi on the corporate subnet [MEDIUM]

- The guest wireless network shares the same IP subnet as corporate devices, allowing guest users potential access to internal resources.
- **Recommendation:**
 - **Move guest Wi-Fi to a dedicated isolated VLAN with internet-only access.**
 - **Ensure no routing paths exist between the guest VLAN and any internal network segment.**

3.3 Remote Access

Finding 7: VPN using deprecated IKEv1/PPTP protocols [HIGH]

- The VPN infrastructure uses IKEv1 and PPTP, both of which have well-documented vulnerabilities.
- PPTP in particular has been deprecated and is considered cryptographically broken.
- Remote employees connecting via this VPN are vulnerable to credential interception and man-in-the-middle attacks.
- **Recommendation:**
 - **Migrate VPN to IKEv2/IPSec or WireGuard. For SSL VPN**
 - **Enforce TLS 1.3.**
 - **Disable all legacy protocol support at the VPN gateway.**

Finding 8: Split tunnelling not enforced [MEDIUM]

- The VPN permits split tunnelling, meaning remote employees' internet traffic does not pass through the corporate network.
- This creates blind spots, malware infections and data exfiltration via non-corporate internet connections go undetected.
- **Recommendation:**
 - **Enforce full tunnel VPN, or at minimum route all DNS queries and non-split traffic through enterprise DNS and a web proxy for monitoring.**

Finding 9: No Zero Trust controls — excessive access post-authentication [MEDIUM]

- Once a user authenticates to the VPN, they receive broad network access regardless of device posture, location, or the specific resources they need.
- This contradicts Zero Trust principles.
- **Recommendation:**
 - **Implement an identity-aware proxy or ZTNA solution.**
 - **Grant per-session, per-resource access based on user identity, device compliance, and context.**
 - **Evaluate solutions such as Cloudflare Access or Zscaler Private Access.**

3.4 Endpoint and Identity Management

Finding 10: No multi-factor authentication enforced [HIGH]

- All user accounts, including administrator accounts, rely on single-factor password authentication.
- Password-based authentication alone is highly vulnerable to phishing, credential stuffing, and brute-force attacks.
- **Recommendation:**
 - **Mandate MFA for all accounts.**
 - **Use TOTP authenticator apps as a minimum.**
 - **Require FIDO2 hardware security keys for all privileged and administrator accounts.**

Finding 11: No EDR deployed — basic antivirus only [MEDIUM]

- Endpoints are protected by signature-based antivirus only.
- Modern threats including fileless malware, living-off-the-land attacks, and zero-day exploits evade signature detection.
- **Recommendation:**
 - **Deploy an EDR solution such as CrowdStrike Falcon, Microsoft Defender for Endpoint, or the open-source Wazuh agent.**
 - **Enable behavioural detection, process monitoring, and automated response capabilities.**

Finding 12: Excessive user privileges — RBAC partially implemented [LOW]

- Role-based access control has been partially implemented, but a review of user accounts reveals that a number of standard users retain administrative or elevated privileges from previous role assignments.
- **Recommendation:**
 - **Conduct a full privilege audit.**
 - **Remove all unnecessary elevated access.**
 - **Formalise an RBAC framework with defined roles, associated permissions, and a quarterly access review process.**

3.5 Data Protection and Visibility

Finding 13: Internal services running without TLS [MEDIUM]

- Several internal web applications and services communicate over unencrypted HTTP.
- Data transmitted between users and these services: including credentials and sensitive business data is exposed to interception on the internal network.
- **Recommendation:**
 - **Enforce HTTPS for all internal services.**
 - **Deploy an internal certificate authority to issue TLS certificates for service-to-service communication.**
 - **Enforce TLS 1.2 minimum; prefer TLS 1.3.**

Finding 14: No centralised logging or SIEM [LOW]

- Security logs are generated by individual devices but not aggregated.
- There is no central platform for log correlation, threat detection, or incident investigation. In the event of a breach, forensic investigation would be severely hampered.
- **Recommendation:**
 - **Deploy a SIEM platform such as Splunk, Elastic SIEM, or Microsoft Sentinel.**
 - **Aggregate logs from firewalls, switches, endpoints, identity providers, and servers.**
 - **Configure correlation rules and alerting.**

Finding 15: No encryption at rest on file servers [LOW]

- File servers storing sensitive HR and Finance data do not have encryption at rest enabled.
- Physical or logical access to the storage media would expose this data in plaintext.
- **Recommendation:**
 - **Enable AES-256 encryption at rest on all file servers storing sensitive data.**
 - **Implement a key management solution such as HashiCorp Vault or cloud-native KMS for secure key storage and rotation.**

4. Summary of Findings

- **High severity (7 findings):**
 - legacy firewall, permissive egress rules, flat network, no ACLs, deprecated VPN protocols, no MFA, no EDR
- **Medium severity (5 findings):**
 - no IDPS, guest Wi-Fi on corporate subnet, split tunnelling, no Zero Trust, HTTP on internal services.
- **Low severity (3 findings):**
 - excessive privileges, no centralised logging, no encryption at rest.

5. Next Steps

- Based on the findings above, the following immediate actions are recommended:
 - **Replace legacy firewall with an NGFW**
 - perimeter security is the first line of defence
 - **Enforce MFA for all users immediately**
 - highest-impact, lowest-effort control
 - **Begin VLAN segmentation design**
 - eliminates the lateral movement risk from the flat network
 - **Migrate VPN to IKEv2 or WireGuard**
 - deprecated protocols pose direct risk to remote workers
- These findings and recommendations inform the proposed secure network architecture.